

Chapitre 3 — Firewalling et segmentation réseau

3.1 Rappels sur le modèle OSI

Un pare-feu (firewall) est un dispositif de filtrage opérant principalement aux couches 3 (réseau) et 4 (transport) du modèle OSI. Il analyse les en-têtes des paquets IP pour décider d'autoriser ou de bloquer un flux réseau selon un ensemble de règles ordonnées appelées politique de filtrage. Les firewalls modernes (NGFW) intègrent également une inspection de la couche 7 (applicative) permettant la détection de protocoles indépendamment du port utilisé.

3.2 Politique de filtrage stateless vs stateful

Un firewall **stateless** examine chaque paquet indépendamment. Il ne maintient aucun état de connexion, ce qui le rend rapide mais limité : il ne peut pas distinguer un paquet de réponse légitime d'un paquet intrusif partageant les mêmes caractéristiques. Un firewall **stateful** maintient une table d'état (connection tracking) qui lui permet de n'autoriser que les paquets appartenant à des sessions établies par l'hôte interne.

3.3 Exemple de règles iptables

```
# Politique par défaut : tout bloquer
iptables -P INPUT DROP
iptables -P FORWARD DROP
iptables -P OUTPUT ACCEPT

# Autoriser les connexions établies
iptables -A INPUT -m state --state ESTABLISHED,RELATED -j ACCEPT

# Autoriser SSH depuis le réseau admin uniquement
iptables -A INPUT -p tcp --dport 22 -s 192.168.10.0/24 -j ACCEPT

# Autoriser HTTP/HTTPS pour le serveur web
iptables -A INPUT -p tcp --dport 80 -j ACCEPT
iptables -A INPUT -p tcp --dport 443 -j ACCEPT
```

3.4 Segmentation VLAN

La segmentation réseau consiste à diviser un réseau physique en plusieurs réseaux logiques (VLAN) afin de limiter la portée d'une compromission. Une bonne pratique est de séparer au minimum : le réseau utilisateurs, le réseau serveurs, le réseau administration (OOB) et le réseau DMZ.

VLAN	Plage IP	Rôle	Accès autorisés
VLAN 10	10.0.10.0/24	Étudiants	Internet, Moodle

VLAN 20	10.0.20.0/24	Enseignants	Internet, Moodle, NFS
VLAN 30	10.0.30.0/24	Serveurs	Restreint
VLAN 40	10.0.40.0/24	Administration	SSH, RDP interne

Points clés à retenir

- La politique par défaut doit toujours être **DROP** (liste blanche).
- Les règles sont évaluées dans l'ordre : la première règle qui correspond s'applique.
- Un VLAN n'est pas une sécurité en soi : il doit être couplé à un filtrage inter-VLAN.
- La journalisation des flux rejetés est indispensable pour la détection d'incidents.